IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad _____ Grup _____ Tarih _____

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi
Üretim PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · konveyör/motor sürücüleri · görüntü işleme/YZ birimi [V] · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1 **Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.**
(Aşağıdaki tablo)

Bölge	Varlıklar	Gerekçe
Z1 · Safety	Emniyet PLC'si, ışık perdesi/kapak kilidi girişleri, STO/Kontaktör	En yüksek kritiklik: insan güvenliği
Z2 · Kontrol	Üretim PLC, HMI, konveyör/motor sürücüleri, görüntü işleme/YZ birimi	Üretimi çalıştıran, ortak kritiklikte cihazlar
Z3 · Bakım/Mühendislik	Servis hesapları, 2 USB giriş noktası, yazılım yükleme	Konfigürasyon değiştirme yetkisi taşır
Z4 · DMZ / Uzak erişim	Uzak bakım modülü (taşınır), jump server, VPN, oturum kaydı	İç ağ ile dış dünya arasında ara nokta
Z5 · Dış / Kurumsal	Bulut telemetri, Wi-Fi AP, ofis ağı	Düşük güven, internete/kişilere açık

2 **Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?**
İnternete doğrudan açık olduğu için doğası gereği **dış bölgeye (Z5)** düşer; ama kontrol cihazlarına ulaştığından fiilen Z2/Z3'e dokunur. Bu haliyle **kalamaz**: güvenilmeyen bir bölgedeki erişim noktası kritik bölgeye aracısız köprü olur, tek ele geçirilmiş hesap tüm cihaza ulaşır. Çözüm yönü: modülü DMZ'ye (Z4) almak, erişimi jump server + VPN + MFA'dan geçirmek; Safety PLC'ye uzaktan yazma yolu bırakmamak.

3 **Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?**
(Aşağıdaki tablo)

Conduit	Kontrol edilecek
Z5 ↔ Z4 (internet → DMZ)	VPN, MFA, güvenlik duvarı; yalnızca onaylı kaynak ve zaman
Z4 ↔ Z3 (DMZ → bakım)	Jump server, kişisel hesap, tam oturum kaydı, onay akışı
Z3 ↔ Z2 (bakım → kontrol)	Yalnız gerekli port/protokol, yazılım yükleme yetkisi, değişiklik kaydı, USB tarama
Z2 ↔ Z1 (kontrol → safety)	**En sıkı kapı:** minimum veri (durum okuma), safety parametresine yazma yok, reset yerel/fiziksel
Z2 ↔ Z5 (bulut telemetri)	Yalnız dışarı yönlü veri, komut kabul etmez, veri filtreleme

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server** — tek, izlenebilir, kontrol edilebilir geçit; doğrudan erişimde kritik ağa tek açık kapı olur.
Tünel?	Açık / VPN	**VPN** — trafiği şifreler ve erişimi sınırlar; açık bağlantı dinlenebilir/saldırıya açıktır.
Kimlik?	Parola / MFA	**MFA** — çalınan/zayıf parola tek başına yetmesin.
Hesap?	Paylaşılan / Kişisel	**Kişisel** — kim ne yaptı belli olur, tek kişinin yetkisi iptal edilebilir.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı** — olay sonrası kanıt, CRA bildirimi ve denetim için gerekli.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı** — yalnız onaylı bakım penceresinde açılır; sürekli açık kapı sürekli saldırı yüzeyidir.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

[V] = cihaz şartnamesi bulunmadığı için yapılan varsayım; cihazınıza göre düzeltin. Mavi yazı = doldurulmuş cevaplar.